

# RASTRO

## Trazabilidad verificable de envíos

Sergio Montoya · Nicolás Torres · Oscar Rincón
Cloud Computing (ISD38) · Grupo 30112

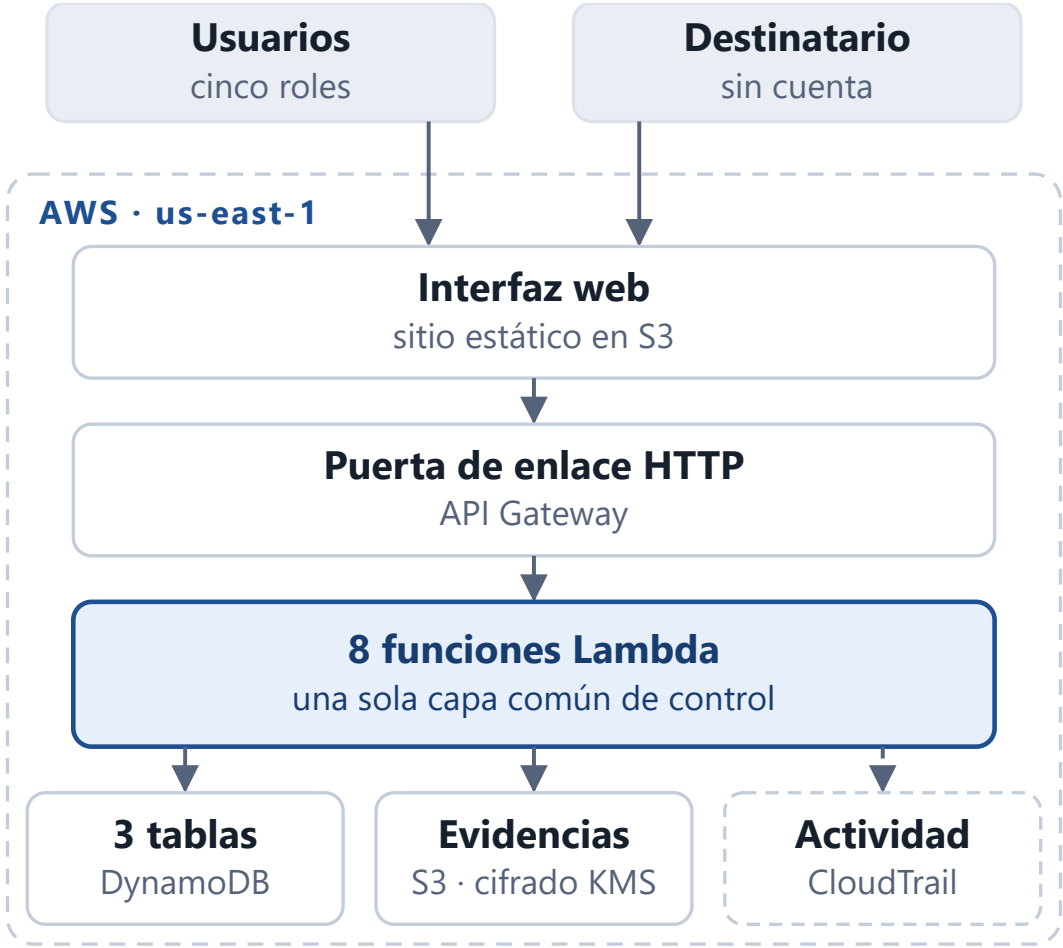
# El problema y el sistema

**Hoy.** En una mensajería urbana pequeña de Bogotá, el estado de un envío vive en la memoria del mensajero, un chat, una hoja de cálculo y el teléfono del despachador.

**Nadie puede decir quién cambió el estado, cuándo y con qué respaldo.**

**Rastro** obliga a que cada cambio quede **atribuido, fechado y validado** contra las transiciones permitidas.

AWS `us-east-1` : ocho funciones, tres tablas, almacén cifrado y registro de actividad. Varias empresas, datos aislados.



BLOQUE 2 · PLANIFICACIÓN

# Objetivo, alcance y plan

**Objetivo.** Registrar de forma **verificable** el ciclo de vida de cada envío, con acceso por rol, aislamiento entre organizaciones y evidencia cifrada.

| Fase | Semanas | Responsable |
|---|---|---|
| **Diagnóstico y validación de supuestos** | 1–2 | Oscar Rincón |
| **Diseño** | 3–4 | Sergio Montoya |
| **Construcción y despliegue** | 5–9 | Nicolás Torres · Sergio Montoya |
| **Verificación y cierre** | 10–12 | Oscar Rincón |

**Fuera del alcance:** rastreo continuo del vehículo, rutas, aplicación nativa, notificaciones.
**Recursos:** 50 dólares por cuenta; único cargo fijo, la llave de cifrado.
**Declarado como no logrado:** retención inmutable del almacén.

# Metodología y técnicas

Enfoque **iterativo e incremental**: una fase por objetivo.

> **Ningún requisito se dio por cumplido antes de tener su prueba automatizada.**

| Técnica | Por qué esa |
|---|---|
| **Decisiones de arquitectura registradas antes de implementar** | Código y documento no se contradicen |
| **Prueba mínima de cada capacidad del laboratorio** | Comprobar antes de construir encima |
| **Pruebas unitarias y de extremo a extremo** | Reglas y requisitos, sin credenciales |
| **Verificación posterior al despliegue** | Lo desplegado existe y responde |
| **Auditoría independiente** | Quien despliega no concluye que su control funciona |

# Riesgos y controles

| Riesgo | Prob. | Impacto | Respuesta | Estado |
|---|---|---|---|---|
| **Consulta sin filtrar por organización** | Media | Muy alto | Clave `ORG#…#ENV#…` · control C-06 | No materializado |
| **Exposición de secretos** | Media | Muy alto | Rotación y control C-09 | **Materializado y corregido** |
| **El laboratorio bloquea un servicio** | Media | Alto | Puerta de enlace | Materializado y resuelto |
| **El alcance crece y no se termina** | Alta | Alto | Regla de la prueba | Materializado y gestionado |
| **Se agota el presupuesto** | Media | Alto | Nada que facture entre sesiones | No materializado |

**Otros controles:** autorización por operación (C-05), bitácora encadenada (C-08), cifrado con llave propia (C-02, C-03), identificadores aleatorios.
**Faltan, porque el entorno lo impide:** rol de ejecución por función y ancla de integridad fuera de la cuenta.

# Roles y separación de funciones

| Rol | Puede | No puede |
|---|---|---|
| **Administrador** | Todo: envíos, catálogos, cuentas y roles | **Leer la bitácora** |
| **Coordinador** | Despachar, reanudar incidencias, editar catálogos | Administrar cuentas |
| **Despachador** | Crear y asignar envíos, registrar eventos | Reanudar incidencias |
| **Conductor** | Ver **sus** envíos, marcar avance, cargar evidencia | Crear o asignar envíos |
| **Auditor** | Consultar y **leer la bitácora** | Cualquier escritura |

**Ningún rol ni cuenta combina escritura con lectura de la bitácora.** No es configurable.
**Quien detiene un envío no es quien lo reanuda.** Nadie concede un permiso que no tiene.

BLOQUE 5 · NORMATIVAS

# Normativas y cumplimiento

| Marco | Cómo se cumple |
|---|---|
| **Ley 1581 de 2012** | Minimización, cifrado, acceso por rol; solo datos sintéticos |
| **ISO/IEC 27001:2022** | Llave propia con rotación; versionado |
| **CIS AWS Benchmark** | Registro con validación de integridad; sin acceso público |
| **OWASP Top 10:2021 A01** | Identificadores aleatorios; 404 y no 403 entre organizaciones |
| **NIST SP 800-92** | Bitácora con actor, acción, recurso y momento |
| **AWS Well-Architected** | **Mínimo privilegio: no se cumple** |

Auditoría independiente contra el sistema desplegado:

**11**
controles

**10**
conformes

**1**
desviado

**0**
sin ejecutar

BLOQUE 6 · HALLAZGOS Y EVIDENCIAS

# Evidencias y hallazgo principal

| 234 | 4 | 0 | 14 |
|---|---|---|---|
| superadas | omitidas | fallos | segundos |

**Despliegue verificado** el 26/09/2026, código de salida 0: tablas, llave, funciones, puerta de enlace y registro de actividad.

| | |
|---|---|
| **Condición** | Un secreto de firma quedó publicado en el repositorio durante 27 minutos |
| **Criterio** | ISO/IEC 27001 A.5.17 y A.8.4 |
| **Causa** | La exclusión existía y se retiró en bloque al versionar las evidencias |
| **Corrección** | Rotación, redespliegue de las ocho funciones, comprobación de rechazo y control C-09 |

# Conclusiones y mejoras

- Los **nueve requisitos** se cumplen y pueden comprobarse
- **Tres verificaciones independientes** coinciden: pruebas, despliegue y auditoría externa
- Tres riesgos materializados, los tres gestionados

| Acción prioritaria | Responsable | Tiempo |
|---|---|---|
| **Reescribir el historial del repositorio** | Nicolás Torres | 2 horas |
| **Rol de ejecución por función** | Sergio Montoya | 1 semana · depende del entorno |
| **Validar con una empresa real** | Oscar Rincón | Un semestre |

**Limitaciones:** sin usuarios reales · mínimo privilegio incumplido · integridad por detección, no prevención.

`github.com/Serann10255/Rastro`